> **位置**：总索引 | **上游**：网络安全（上）（安全 01） | **下游**：网络安全科完结 → 872 全科收尾
>
> 本篇覆盖原笔记第 7–12 章；上篇覆盖第 1–6 章。

7. 防火墙技术

7.1 防火墙定义与基础

定义：一种部署于不同网络安全域之间的高级访问控制设备，它通过相关的安全策略控制（允许、拒绝、监视、记录）进出网络的访问行为。

- **部署位置**：网络边界。
- **基础功能**：过滤。

7.2 防火墙的检测与过滤技术（核心）

技术	检测机制	工作层	简要特点
包过滤（Packet Filter）	根据数据包头部 IP 地址、端口、协议类型等标志确定是否允许数据包通过	网络层	速度快、配置简单；**不检查数据区**，不建立连接状态表，应用层控制弱，易受 IP 欺骗
应用代理（Application Proxy）	通过编写不同的应用代理程序实现对应用层数据（数据负载）的检测和分析	应用层	**不检查 IP、TCP 报头**；不建立连接状态表；网络层保护比较弱
状态检测（Stateful Inspection）	访问控制方式与包过滤同，但处理的对象不是单个数据包，而是整个连接，通过规则表和连接状态表综合判断是否允许数据包通过	2–4 层	检查**整个连接**；不检查数据区；建立连接状态表；前后报文相关；应用层控制很弱；性能高，支持大量应用
完全内容检测（Complete Content Inspection）	全部数据（报头至应用层内容）不仅分析数据包头信息、状态信息，而且对应用层协议还进行还原和内容分析，有效防范混合型安全威胁	2–7 层	最全面，能还原协议并分析内容；网络层保护强；应用层保护强；会话保护很强；上下文相关；前后报文有联系

7.3 三种典型防火墙的特点（简答题）

7.3.1 包过滤防火墙

优点

- 只对数据包的 IP 地址、TCP/UDP 协议和端口进行分析，规则简单，处理速度较快

- 易于配置
- **对用户透明**——用户访问时不需要提供额外的密码或使用特殊的命令

缺点

- 检查和过滤器只在网络层——不能识别应用层协议或维持连接状态
- 安全性薄弱——不能防止 IP 欺骗等
- 静态策略可能成为漏洞

7.3.2 应用代理或网关防火墙特点（简答题）

优点

- 可以检查应用层、传输层和网络层的协议特征，对数据包的检测能力比较强
- 提供良好的安全性——所有数据的有效负载都在应用层进行检查

缺点

- 支持的应用数量有限，无法很好的支持新的应用、技术和协议
- 对用户不透明
- 性能表现欠佳

> 但是，自适应代理技术的出现让应用代理防火墙技术出现了新的转机，它结合了代理防火墙的安全性和包过滤防火墙的高速度等优点，在不损失安全性的基础上大大提高了代理防火墙的性能。

7.3.3 状态检测防火墙

- 性能大大提高
- 支持大量应用
- 在内核级实现检测过滤
- 在所有接口对进/出的数据包进行状态检查
- 支持应用层协议检查
- 在动态状态表中存储连接状态
- 检查对外的连接并预先计算出将返回的连接

"策略明明拒绝，连接却建立了"的机制解释（场景化理解）

状态检测的核心是维护一张**动态连接状态表**（会话五元组 + 状态标志），表项在连接发起时创建、结束时删除：

步骤	发生的事	状态表如何处理
1	内网主机向外发起访问，出站 **SYN** 放行	新建表项：内网 IP:端口 → 外网 IP:端口，状态置为"等待 SYN-ACK"
2	外网回送 **SYN-ACK**	查表命中"等待 SYN-ACK"，判定为**对该连接的合法响应**，放行并推进状态
3	内网主机回 **ACK**，三次握手完成	表项转为"已建立"，此后双向报文均按该表项放行
4	会话结束	表项超时或收到 FIN/RST 后删除

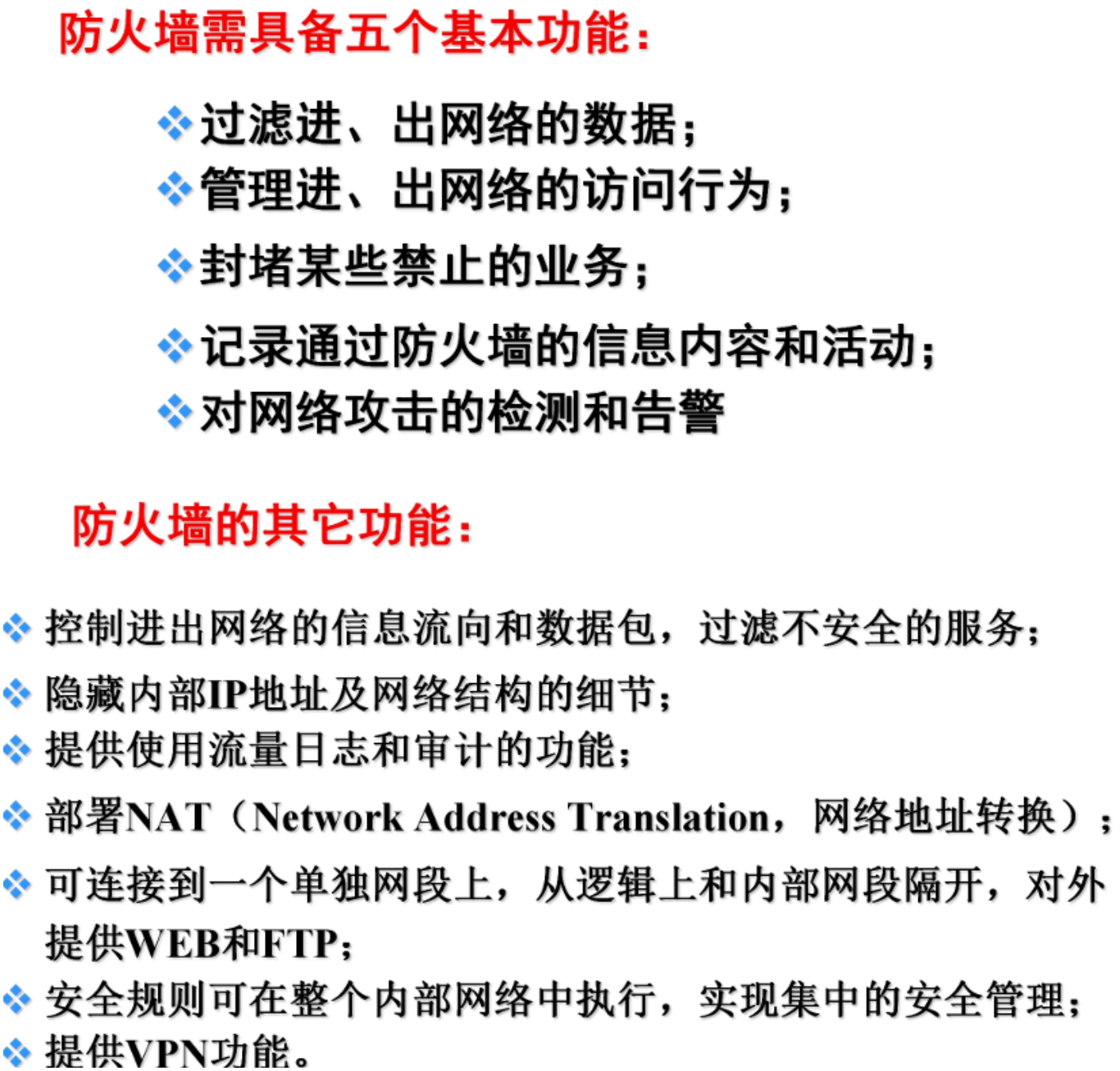
由此可以解释两类现象：

- **默认策略是拒绝，最终连接却建立成功了**——"拒绝"针对的是**查不到表项的报文**。由于出站 SYN 先于入站响应到达并建好了表项，后续报文全部命中表项，连接得以完整建立。
- **已禁止未经请求的访问，却仍收到了（并放行了）TCP 的确认报文**——该 ACK/SYN-ACK 能在状态表中匹配到此前记录的**出站请求**，因此被判定为"**已获授权的会话数据**"，而不是"未经请求的访问"。

为什么无状态包过滤做不到：包过滤只能逐个检查报文头的五元组，无法区分"**未经请求的 SYN-ACK**"和"**对内部请求的正常响应**"——这两种报文在头部字段上可以完全相同。判断"该不该放行"需要连接的**上下文**，而上下文只有状态检测才掌握。

> 题目里只要出现"策略禁止却仍被放行""收到了不该收到的响应 / 确认报文"这类描述，答案基本就是**状态检测（会话跟踪）机制**。

7.4 防火墙其他重要功能详解

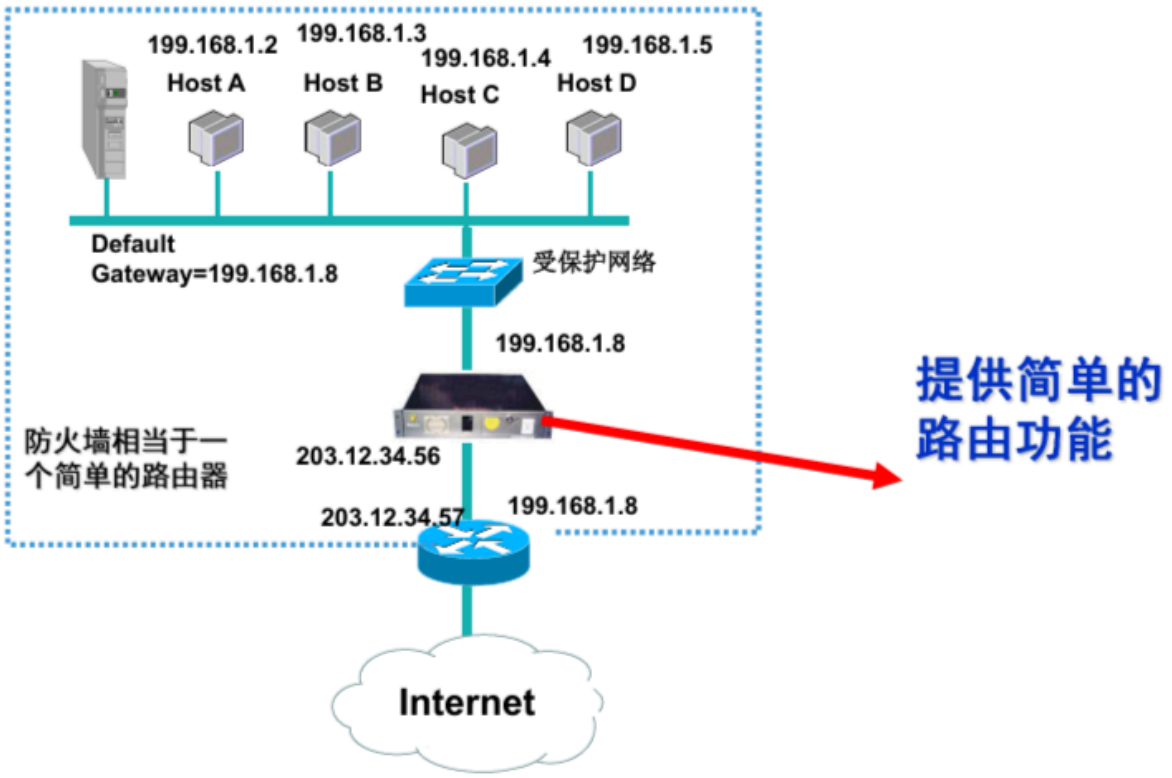


功能	做法	好处/作用
地址转换（NAT）	将内部网络的私有 IP 地址转换为对外的公有 IP 地址	隐藏内部网络结构，实现 IP 地址复用，解决公网地址不足问题
地址/端口映射（MAP）	将公网 IP 的特定端口映射到内部服务器的私有 IP 和端口	让使用私有地址的服务器能对外提供服务，同时隐藏内部网络结构
IP 与 MAC 地址绑定	绑定 IP 与 MAC 的对应关系	防止 IP 地址欺骗和滥用。例如，绑定后，防火墙允许 Host A 上网，但会阻止 Host B 假冒 Host A 的 IP 地址上网
与 IDS 的安全联动（重点）	防火墙可以与入侵检测系统（IDS）联动。当 IDS 识别出攻击时，可通知防火墙采取措施	如阻断连接

7.5 防火墙的工作接入方式

7.5.1 路由接入方式

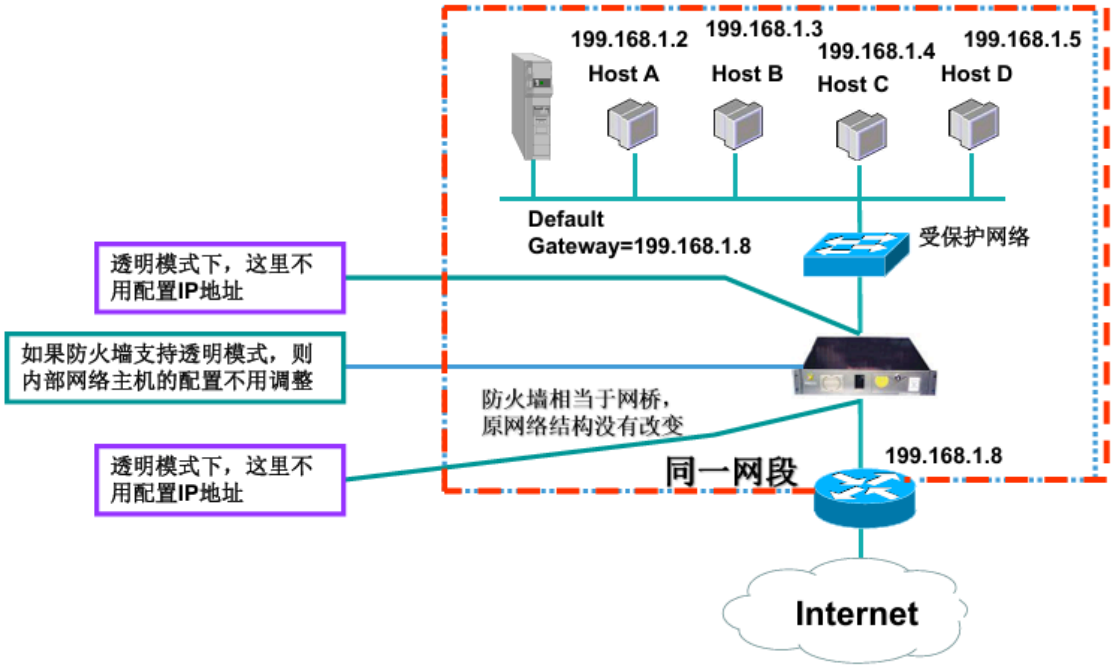
防火墙作为一个**简单的路由器**（同时是网关），需要配置 IP 地址，连接不同网段。接在一个普通路由器后面。



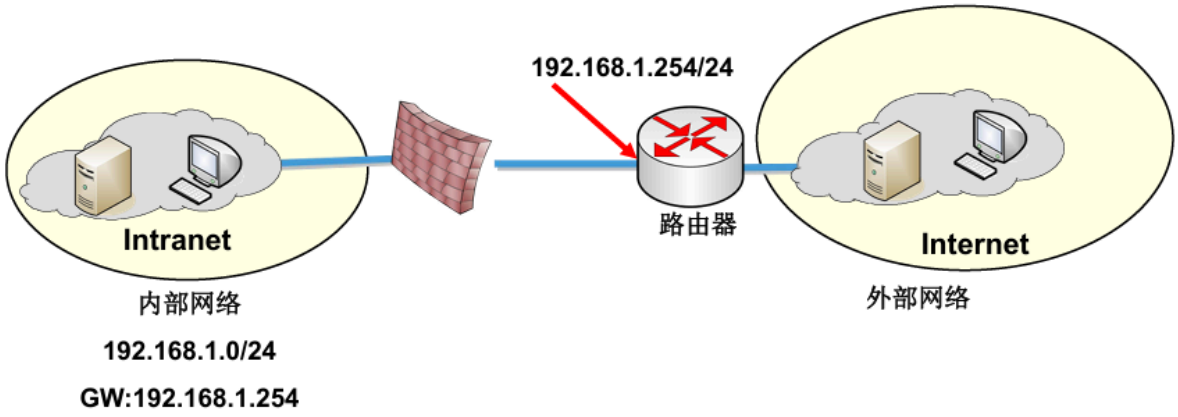
- ✅ **特点 1**：支持多网段隔离（不同接口配置不同网段，实现 VLAN 间路由和访问控制）
- ✅ **特点 2**：路由策略灵活，可基于目标网段、协议、端口做精细转发

7.5.2 透明接入方式

防火墙相当于**网桥**，不改变原网络拓扑和主机配置，接口无需 IP 地址。（红字是特点）



防火墙的透明接入工作模式

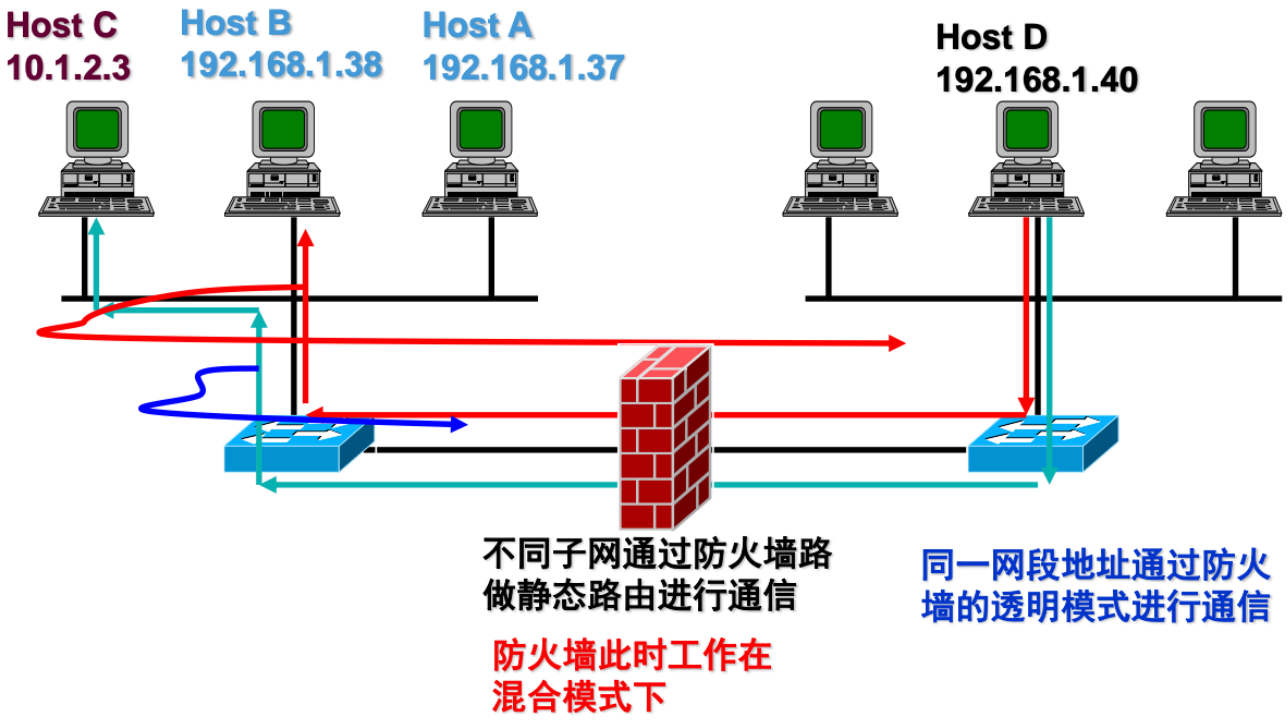


7.5.3 混合接入方式

同时支持以上两种模式，根据网络需求灵活部署。

- 工作于**透明接入模式**的防火墙可以实现透明接入。
- 工作于**路由模式**的防火墙可以实现不同网段的连接。
- **路由接入模式的优点和透明接入模式的优点是不能同时并存的。**
- 大多数的防火墙一般同时保留了透明接入模式和路由接入模式。
- 根据用户网络情况及用户需求，在使用时由用户进行选择。

防火墙的混合接入工作模式



7.6 衡量防火墙性能的五大指标

指标	含义
吞吐量	在不丢包的情况下，设备能够转发的最大数据速率。吞吐量小会成为网络瓶颈
时延	数据包第一个比特进入设备到最后一个比特输出设备的时间间隔。时延越小性能越好
丢包率	在连续负载下，设备应转发却未转发的数据包百分比。丢包率越小性能越好
背靠背	从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧， 当出现第一个帧丢失时，发送的帧数。体现防火墙对突发数据流的处理能力，主要考察设备缓冲容量
并发连接数	数据包穿越防火墙同时建立的的最大连接数。主要用来测试防火墙建立和维持 TCP 连接的性能。 并发连接数越大，处理能力越强

背靠背补充说明：通俗来说，"背靠背"测试就像是你尽可能快地通过网络发送数据到阈值，直到网络开始丢包，然后你看看在丢包发生之前你成功发送了多少数据。这有助于了解你的网络在高负载下的表现如何。衡量标准：背对背包主要是指防火墙**缓冲容量的大小**；网络上经常有一些应用会产生大量的突发数据包（例如 NFS、备份、路由更新等），而且这样的数据包的丢失可能会产生更多的数据包的丢失，强大缓冲能力可以减小这种突发对网络造成的影响。

7.7 防火墙的"胖瘦"之争

	"胖"防火墙	"瘦"防火墙
定义	功能大而全的防火墙，集成访问控制、病毒防护、 入侵检测等多种安全功能。	指功能少而精的防火墙， 专注于核心的访问控制功能， 通过与其他安全产品联动形成解决方案

	"胖"防火墙	"瘦"防火墙
	它力图将尽可能多的安全功能包含在内， 从而成为用户网络的一个安全平台	
优势	功能全、控制力度细，协作能力强，降低采购和管理成本	性能高、专业性强、配置简单
不足	性能可能降低，配置复杂，稳定性不强（系统越大 bug 越多），自身安全性相对较弱	功能单一，整体采购成本可能较高

8. 入侵检测技术

8.1 核心概念

概念	定义
入侵	指在非法或未经授权的情况下，试图存取或处理系统或网络中的信息，或破坏系统/网络正常运行，致使机密性、完整性和可用性受到破坏的**故意行为**
入侵检测	对入侵行为的发觉。通过从计算机系统或网络的关键点采集信息并进行分析， 从中发现违反安全策略的行为和被攻击的迹象
入侵检测系统	实现入侵检测功能的软件和硬件的集合

8.2 入侵检测模型

模型	说明
通用入侵检测模型（也称为 Denning 模型）	核心思想是通过检查系统的审计记录，从中识别异常使用系统的入侵行为。 它是一个**基于规则的模式匹配系统**
层次化入侵检测模型	将入侵检测过程分为六个抽象层次：数据层、事件层、主体层、上下文层、 威胁层和安全状态层，通过数据关联简化对跨主机入侵行为的识别
管理式入侵检测模型（即 SNMP-IDSM 模型）	重点解决多个 IDS 之间的协同工作问题

8.2.1 工作原理（重点掌握）

- 假设 IDS A 监视主机 A，IDS B 监视主机 B。
- 当 IDS A 检测到一个来自主机 B 的攻击企图时，它会使用 **MIB（管理信息库）脚本**向 IDS B 发送请求。
- IDS B 收到请求后，执行脚本（功能类似于 netstat、lsof 等命令），收集主机 B 的网络和用户活动信息。
- IDS B 将这些信息反馈给 IDS A。
- IDS A 根据收到的信息进行进一步的入侵分析验证。

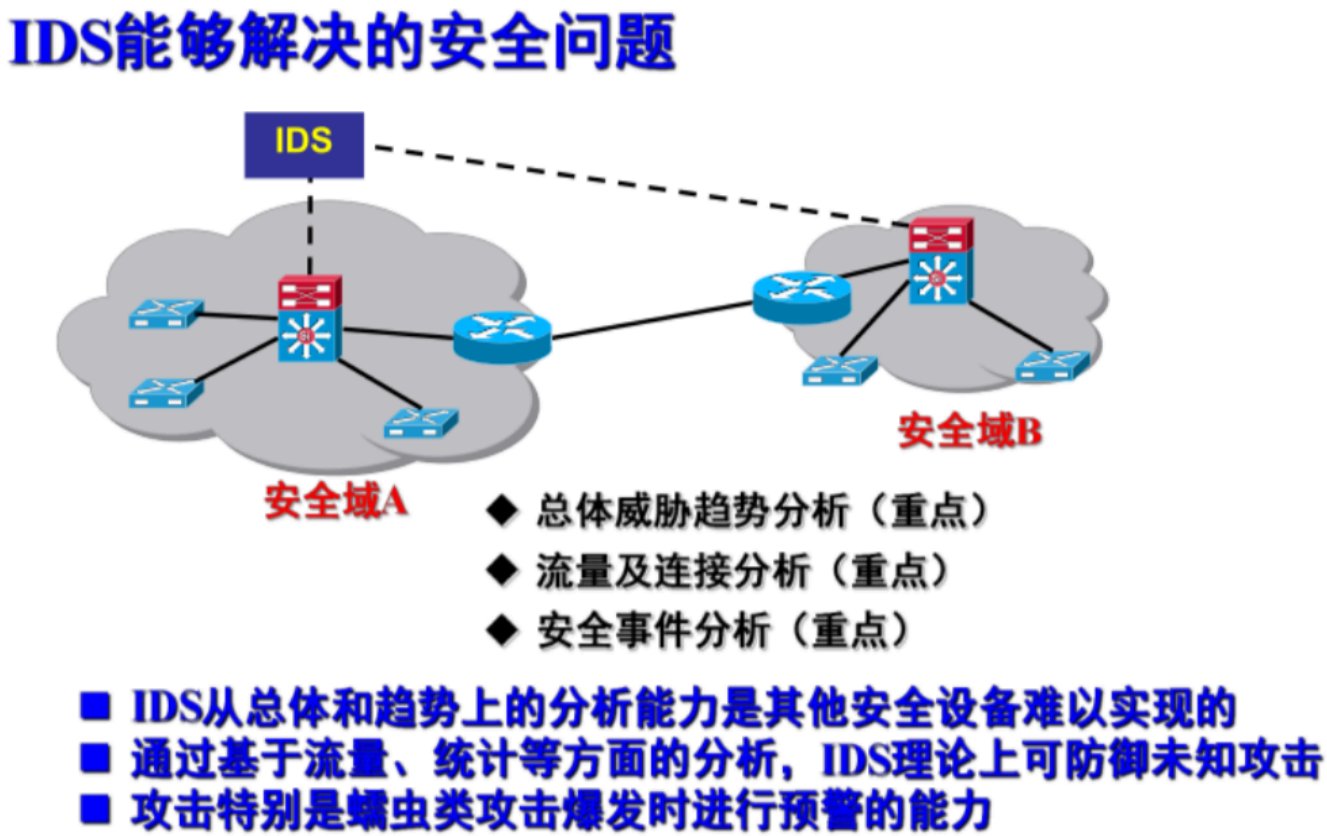
目的：以 SNMP 为公共语言实现 IDS 间的信息交换和协同检测。

8.3 入侵检测系统的分类（按分析技术）

	异常检测	特征检测
是什么 （重点）	首先建立用户或系统的**正常行为模型**（知识库）， 然后检测实际活动是否偏离该正常模型。 假设"所有入侵行为都是异常的"。 也称为**基于行为的检测**	建立**已知入侵行为的模型**（攻击特征库）， 判别当前活动是否符合已知的攻击模式。 假设可以识别所有攻击特征。也称为**误用检测**
优点	可能检测未知攻击，具有自适应性	准确率高，算法简单
缺点	正常模型难以建立，明确划分正常与异常较难	无法检测新的入侵，特征库需不断更新

8.4 IDS 的检测指标

- **漏报率**：指攻击事件没有被 IDS 检测到。
- **误报率**：指将正常事件识别为攻击并报警。
- **关系**：误报率与检出率通常成正比例关系。



9. 其他网络安全技术及设备

9.1 入侵防御系统（IPS）

长定义：IPS 是一种集入侵检测和防御于一体的安全产品，它不但能检测入侵的发生，而且能通过一定的响应方式，实时地中止入侵行为的发生和发展，实时地保护信息系统不受实质性的攻击。IPS 使得 IDS 和防火墙走向统一。

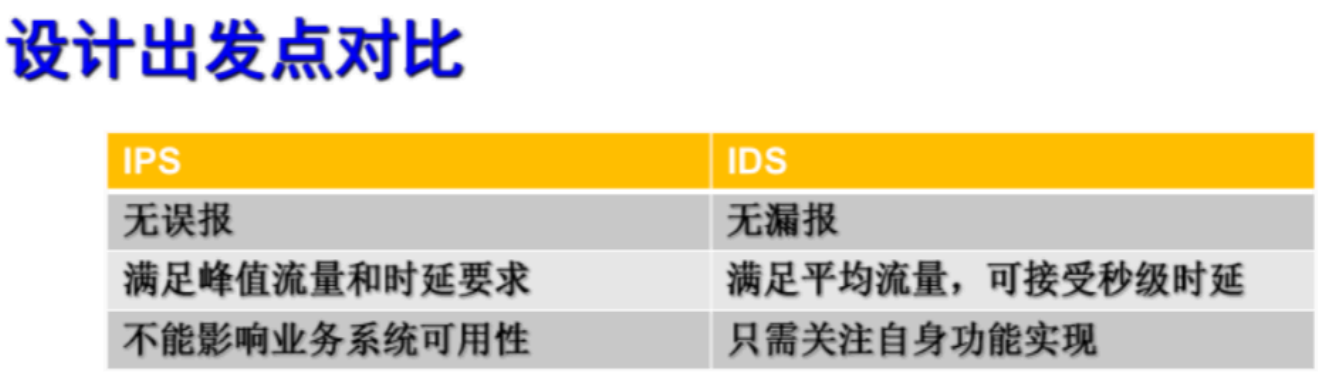
简单理解：可认为 IPS 就是**防火墙加上入侵检测系统**。

简单定义：能够实时检测并主动阻断入侵行为的系统。

9.1.1 与 IDS 的区别（重点）

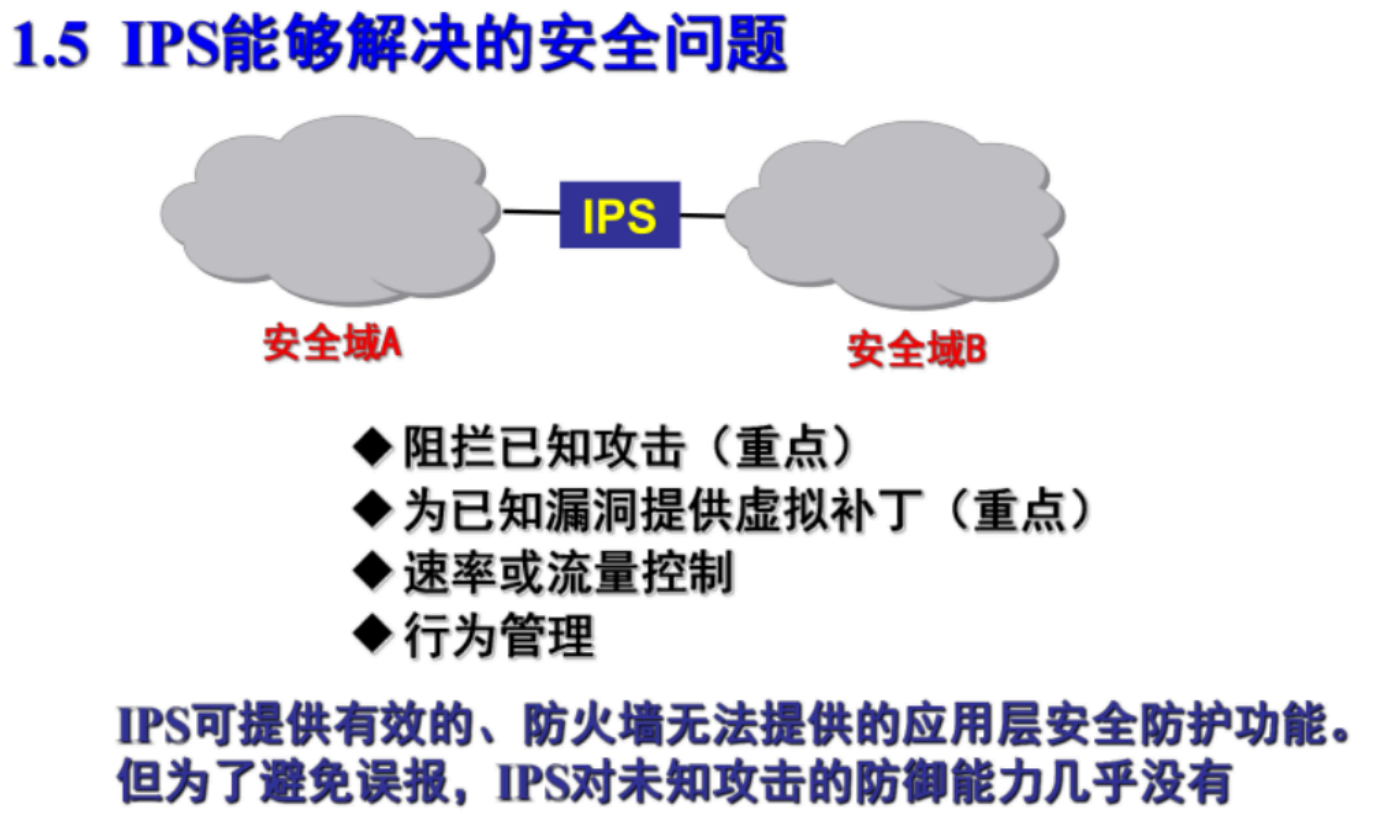
维度	IPS	IDS
部署方式	**在线**，流量必须通过 IPS	**旁路**，通过镜像获得数据
实时性	实时，其时延必须满足业务要求	准实时，可接受秒级时延
影响	立刻影响网络报文	对网络及业务无直接影响
作用范围	作用范围有限制	监控范围广
设计出发点	无误报、满足峰值流量和时延要求、 不能影响业务系统可用性	无漏报、满足平均流量，可接受秒级时延、 只需关注自身功能实现





- **IDS**：旁路监听，主要功能是检测和报警，属于**事后响应**。
- **IPS**：部署在网络边界（在防火墙后或者相同位置），串联部署，具备实时阻断能力，属于**事中防御**。

9.1.2 能解决的安全问题



9.2 安全隔离与信息交换系统（网闸）

定义：网闸是在两个不同安全域之间，通过特殊的通讯协议转换的手段，以信息摆渡的方式实现数据交换，且只有被系统明确要求传输的信息才可以通过。其信息流一般为通用应用服务。

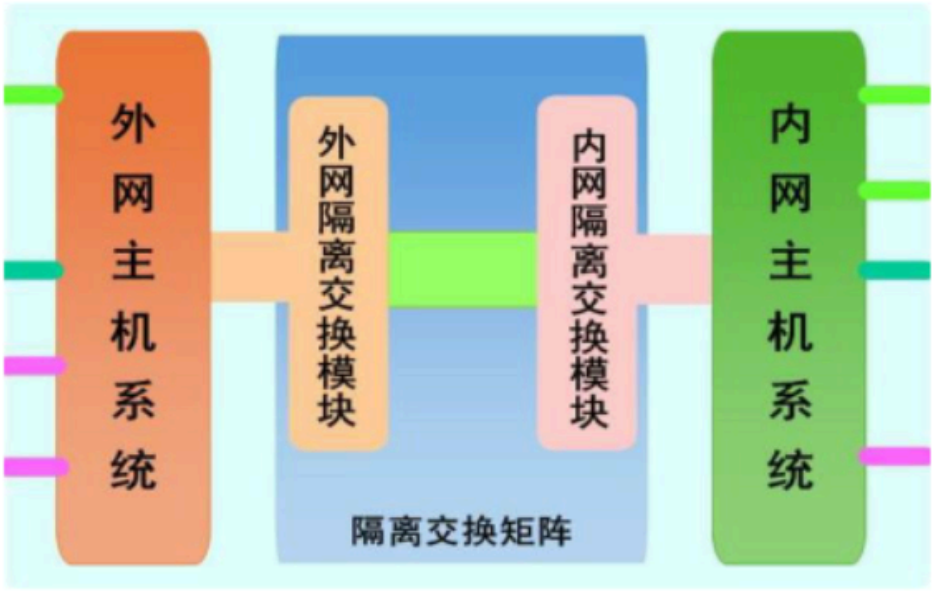
核心思想：在信息摆渡过程中内外网（上下游）**从未发生物理连接**，从而彻底阻断网络层攻击。

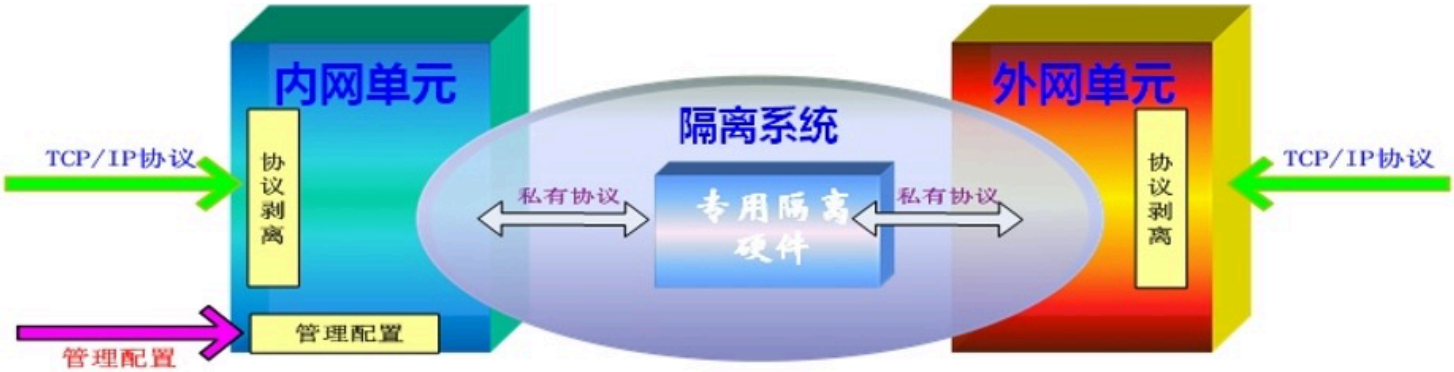
作用：网闸主要用于在两个物理隔离的网络之间进行安全的数据交换。

物理隔离带来的问题与解决：物理隔离保证了安全，但阻碍了必要的数据交换。网闸通过其特殊组成解决此矛盾。

安全隔离网闸的组成：通常由内、外网处理单元和专用的隔离交换硬件（如电子开关、固态介质）组成，数据通过"摆渡"方式单向流动。

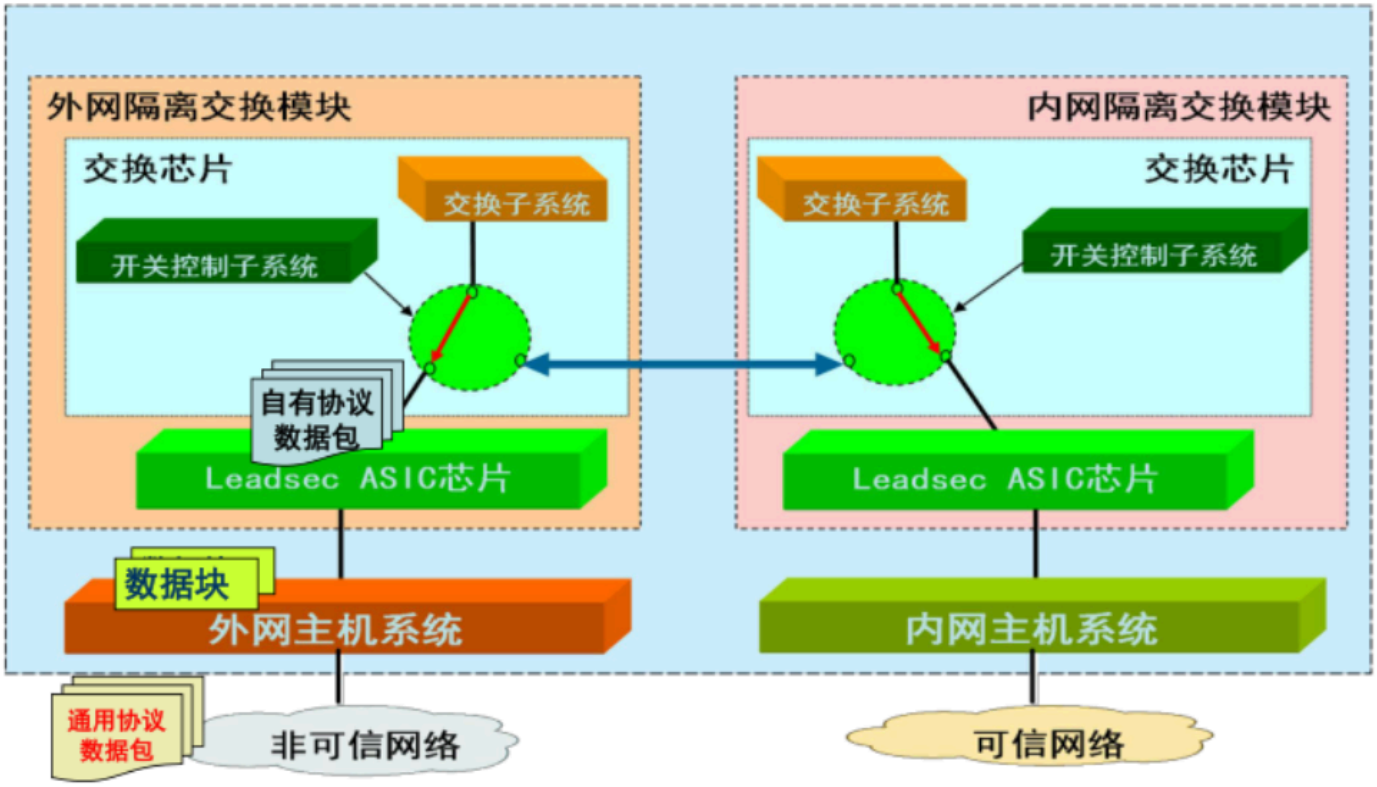
> 概念、原理 + 画出网闸的三个组成部分，再简单说明原理 + 关键字"**私有协议**""**切断**"。





> （要画图，关注安全隔离网闸的组成图里的小字，"私有协议"！考题类似于"画出三个组成部分并说明原理"。）

9.2.1 网闸数据交换过程



组成	功能	工作流程
外网处理单元	面向外部非可信网络。 负责接收来自外网的用户或应用请求	① **协议终止与剥离**：完整终止外网的网络连接（如 TCP/IP），将应用层数据（如 HTTP 内容、数据库查询语句、文件块）从网络数据包中"剥离"出来 ② **深度内容检查**：对剥离出的应用数据进行严格的安全检查，包括病毒木马查杀、恶意代码过滤、内容合规性验证、格式有效性判断等 ③ **数据格式化**：将"净化"后的数据转换为专有的、简化的格式（通常只是一串待交换的原始数据块），准备交由隔离硬件摆渡
内网处理单元	面向内部可信网络。 负责将数据安全地送达内网目标服务器	① **数据接收与重组**：从隔离交换硬件接收已摆渡过来的专有格式数据 ② **协议重建与发起**：以发起方的身份，在内网侧重新建立全新的网络连接，将应用数据重新封装成符合内网标准协议（如 TCP/IP）的数据包 ③ **数据送达**：将重建的数据包发送给内网指定的目标服务器。对于内网向外网发送数据，流程则相反

组成	功能	工作流程
专用隔离交换硬件	实现物理隔离的核心部件， 是内外网处理单元之间的"空气间隙"和"摆渡船"。 **在任何时刻，该硬件只与一侧的处理单元连接，与另一侧完全物理断开**	常见实现方式：**电子开关阵** （通过高速电子开关， 在电路层面实现快速切换连接）；**固态存储介质（如 RAM）** （数据先写入一个与一端相连的存储区， 然后断开连接，切换电路，再让另一端来读取， 存储区在每次读写后都会被擦除）

专用隔离交换硬件工作流程（"摆渡"原理）

1. **连接外网单元**：隔离硬件首先物理连接到外网处理单元，接收其送出的"净化"数据，完成后立即物理断开与外网的连接。
2. **瞬时无连接状态**：此时，隔离硬件与内外网均无连接，处于"孤岛"状态。
3. **连接内网单元**：隔离硬件转而物理连接到内网处理单元，将存储的数据推送给它，完成后再次断开与内网的连接。

> 此过程单向进行，一次摆渡只完成一个方向的数据传输。反向传输需要发起另一次独立的摆渡周期。

9.2.2 网闸与防火墙的区别（重点）

	防火墙	网闸
隔离方式	基于**逻辑隔离**（规则过滤）	基于**物理隔离**
网络连接	存在网络连接	无网络连接
风险	可能遭受协议攻击	从物理上切断 TCP/IP 等协议，安全性更高

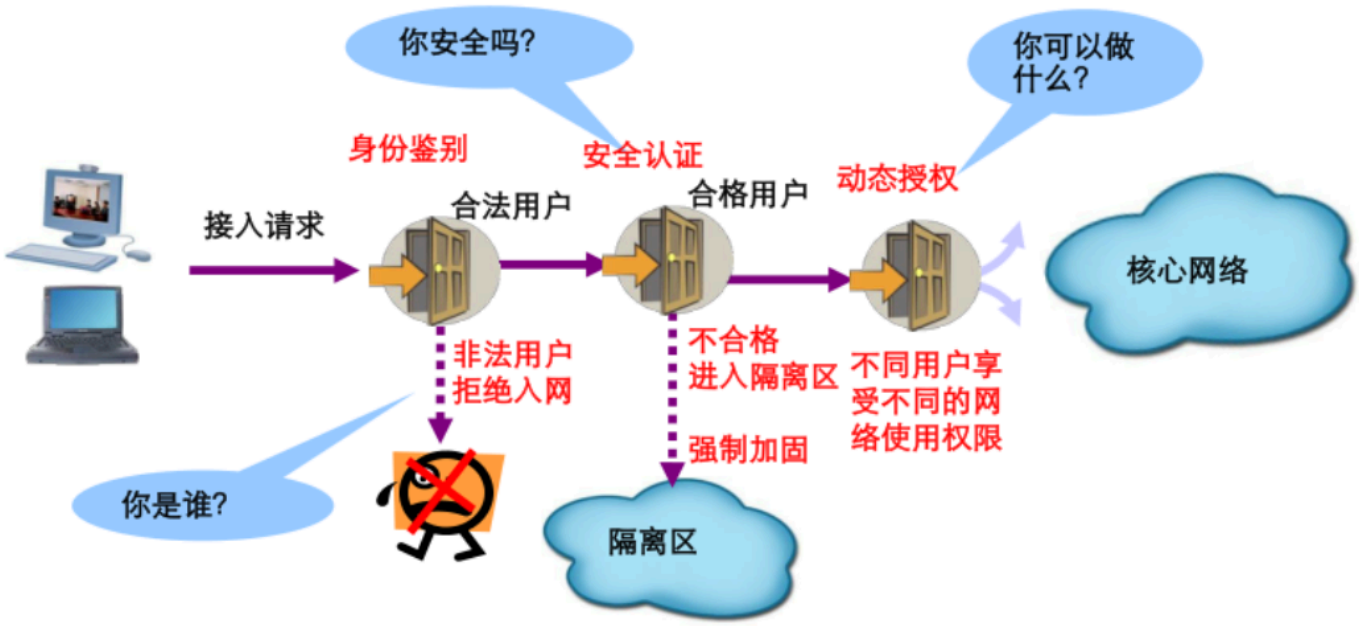
9.3 统一威胁管理系统（UTM）

定义：将防火墙、入侵检测/防御、防病毒、内容过滤等多种安全功能集成于一个硬件平台的设备。

9.4 网络准入控制

定义：使用网络准入安全策略，确保进入网络的设备符合策略。

功能需求与流程



用户接入请求 → 身份鉴别 → 合法用户进行安全认证（非法用户拒绝入网）→ 认证不合格则进入隔离区；认证合格后对用户进行动态授权

> **演进关系**：网络准入控制（NAC）常被视为**零信任**（Zero Trust）的前身与特例——NAC 只解决"能否进入网络"这一次鉴权，零信任把它泛化为"每一个访问请求都重新鉴权"。三条核心原则见网络安全（上） §6.8（该系列课件未设零信任专章，按了解层级记）。

10. 虚拟专用网（VPN）技术

10.1 VPN 基础概念与优点

概念（名词解释）：虚拟专用网（VPN）是一种通过对网络数据封包和加密传输，在公网上传输私有数据、达到私有网络安全级别，从而利用公网构筑企业专用网的组网技术。它兼备公众网的便捷和专用网的安全。

优点

- **降低成本**：利用现有互联网，节省专线费用。
- **易于扩展**：网络扩容方便。
- 可随意与合作伙伴联网。
- 完全控制主动权。

10.2 IPSec 框架

IPSec 是一个协议框架，其安全联盟（SA）规定了通信双方需约定的要素：

1. **加密算法**：如 DES、3DES、AES。
2. **验证（认证）算法**：如 MD5、SHA-1。
3. **安全协议**：AH 或 ESP。

4. **模式**：传输模式或隧道模式。
5. **密钥有效期**：如 3600 秒。

2.1 IPSec框架



（1）加密：DES，3DES，AES...
（2）验证：MD5，SHA-1...
（3）安全协议：ESP，AH...
（4）模式：隧道模式、传输模式...
（5）密钥有效期：3600s，1800s...

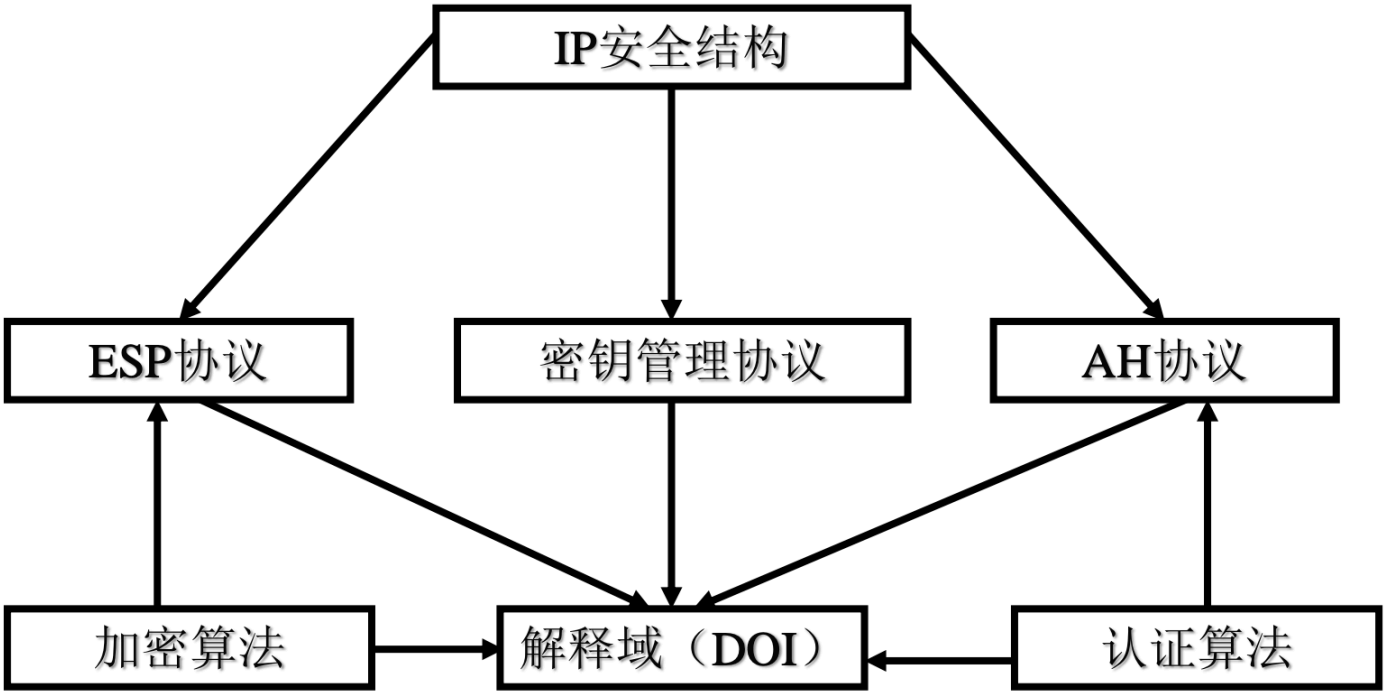
框架固定，不定义具体使用的算法，通信双方自行协商，因此一直使用了30余年



IPSec 对等体之间对某些要素的约定。

安全协议　加密认证算法　封装模式

2.2 IPSec协议体系



IPSec 的安全协议由三个主要的协议组成，它由下图的第二层以及加密和鉴别算法组成。

> 可概括为：**IPsec = 安全协议 + 密钥管理 + SA/数据库 + 工作模式**

10.2.1 安全协议

	AH（Authentication Header）	ESP（Encapsulating Security Payload）
协议号	**51**	**50**
提供	数据完整性、源认证、抗重放	机密性、完整性、源认证、抗重放
不提供	**机密性**	—
认证范围	包括 IP 头中不变字段 + AH 头 + 载荷	认证范围**不包括外层 IP 头**
备注	—	是实际中最常用的 IPsec 协议

10.2.2 密钥管理协议

协议	说明
IKE（Internet Key Exchange）	用于协商 SA、交换密钥、认证对端
ISAKMP	Internet 安全协商和密钥管理协议，是 IPSec 的另一个主要组件
Oakley	提供 DH 密钥交换模式

协议	说明
SKEME	提供认证和密钥交换技术
DOI	解释域，如 IPsec DOI，说明 AH、ESP 等如何使用

IKE 版本

- **IKEv1**：两阶段。阶段 1：建立 ISAKMP SA / IKE SA，主模式或野蛮模式；阶段 2：建立 IPsec SA，快速模式
- **IKEv2**：简化流程，常用 IKE_SA_INIT、IKE_AUTH、CREATE_CHILD_SA

ISAKMP 说明：ISAKMP 提供了用于应用层服务的通用格式，它支持 IPSec 协商方的密钥管理需求。重点在于它**不直接完成密钥交换**，而是规定 SA 从协商、建立到修改、删除的全生命周期管理框架和统一报文格式：报文由 ISAKMP 头和若干载荷组成，载荷可承载 SA、提案、变换、密钥、身份、认证、随机数、通知、删除等信息，交换类型支持主模式、野蛮模式、快速模式等，并通过"阶段一建立 ISAKMP SA/IKE SA、阶段二在其保护下建立 IPsec SA"的两阶段流程为 AH/ESP 服务；IKE 就是基于 ISAKMP 框架，结合 Oakley 的 DH 交换和 SKEME 的认证机制，用 **UDP 500（NAT-T 为 4500）** 实现对等体认证、密钥协商和 SA 维护。

> IKE 使用 **UDP 500**，NAT-T 使用 **UDP 4500**。

10.2.3 SA 与数据库

SA（Security Association，安全关联）

- 是 IPsec 的基础，AH 和 ESP 都依赖 SA
- SA 是**单向**的，双向通信需要两个 SA
- 唯一标识：**SPI + 目的 IP + 安全协议标识**

数据库	用途
SAD（Security Association Database）	存储 SA 参数：SPI、序列号、算法、密钥、生命周期、模式等
SPD（Security Policy Database）	定义什么流量需要 IPsec、如何保护、绕过还是丢弃
PAD（Peer Authorization Database）	用于对端授权认证，RFC 4301 中定义

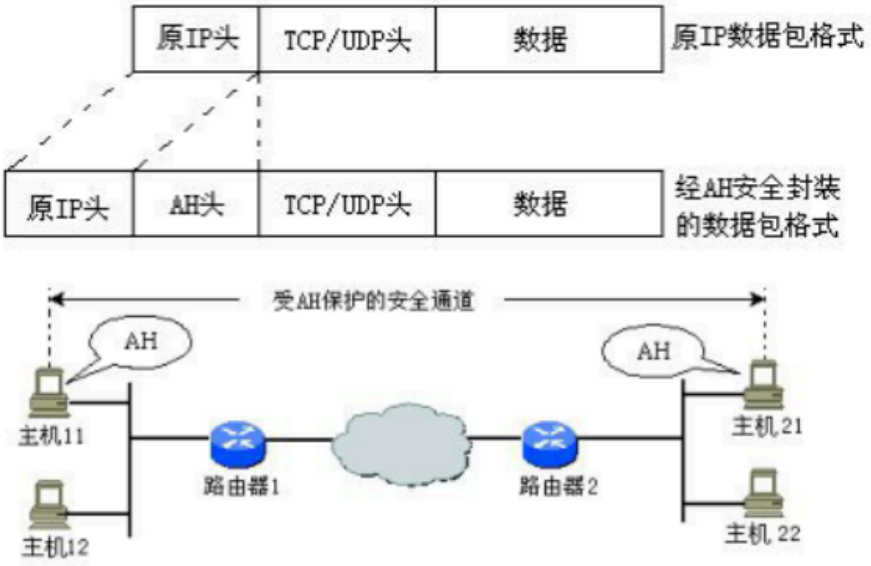
10.3 安全协议：AH

AH 提供数据来源认证、完整性校验和抗重放攻击，**不提供加密。**根据 AH 头插入 IP 包的位置不同，AH 有传输模式和隧道模式。

10.3.1 AH 的传输模式

AH 头插入**原 IP 头后面**。

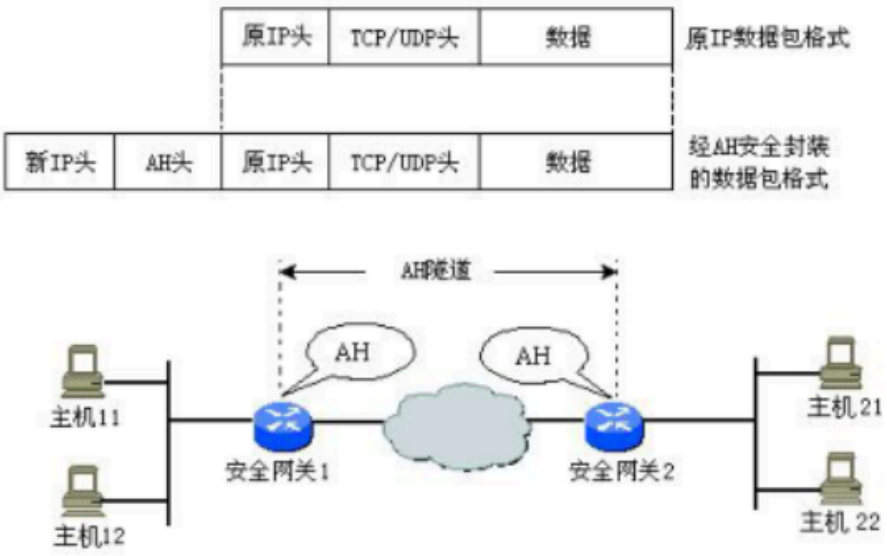
- **AH传输模式**



10.3.2 AH 的隧道模式（重点）

将 AH 头插入**原 IP 分组的 IP 头之前**，并在 AH 头之前添加新的 IP 头。新的 IP 头协议字段为 **51**，表明其后是 AH 头。

- **AH的隧道模式将AH头插入原IP分组的IP头之前，并在AH头之前添加新的IP头，这个新的IP头的协议字段将是51，以表明IP头之后的是一个AH头**



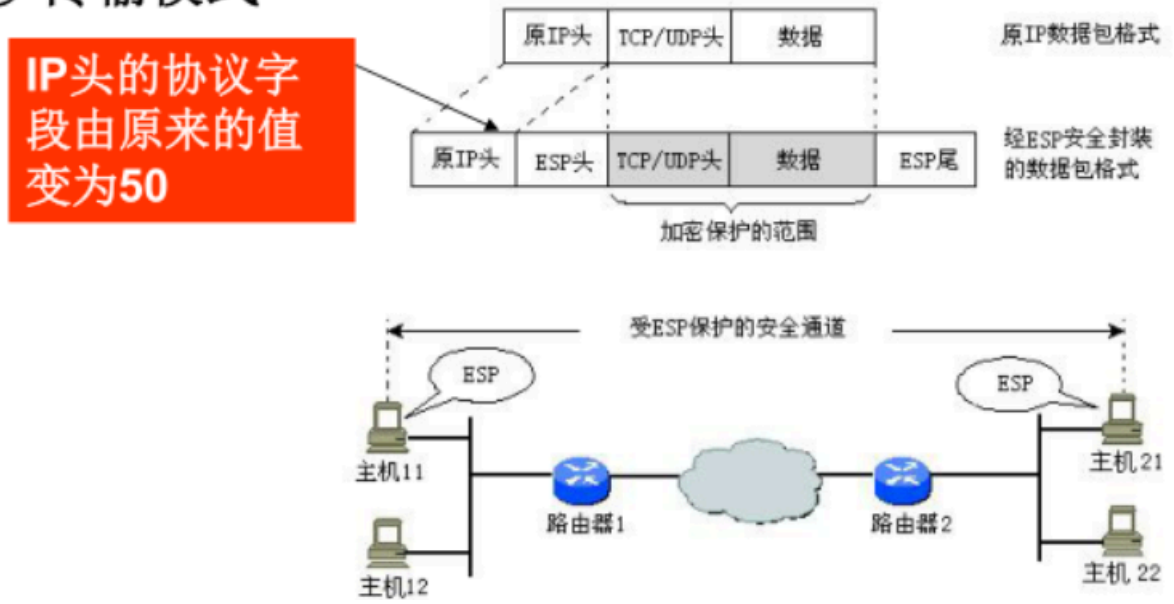
10.4 ESP 协议的传输模式与隧道模式

ESP 提供**加密**，以及数据来源认证、完整性校验和抗重放攻击。

10.4.1 传输模式

IP 头的协议字段由原来的值变为 **50**，用于保护传输层载荷（如 TCP/UDP 数据）。

- 与AH机制相类似，根据ESP封装的载荷内容不同，ESP头可选用两种方式中的一种来应用于IP数据包，即传送模式或隧道模式，其间的差别决定了ESP保护的真正对象是什么
- ① 传输模式

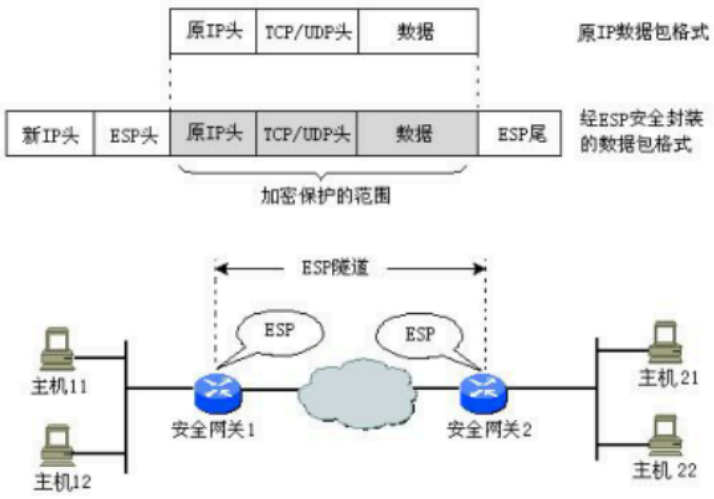


10.4.2 隧道模式

整个原始 IP 包（包括原 IP 头）都被封装在 ESP 有效载荷中，并产生一个新的 IP 头附着在 ESP 头之前。新 IP 头的协议字段为 **50**。隧道模式能**保护子网内部拓扑，支持使用私有 IP 地址**。

② 隧道模式

- 在隧道模式，整个IP包（包括原IP包头）都被封装在ESP有效载荷中，并产生一个新IP头附着在ESP头之前，这个新的IP头的协议字段将是50，以表明IP头之后的是一个ESP头



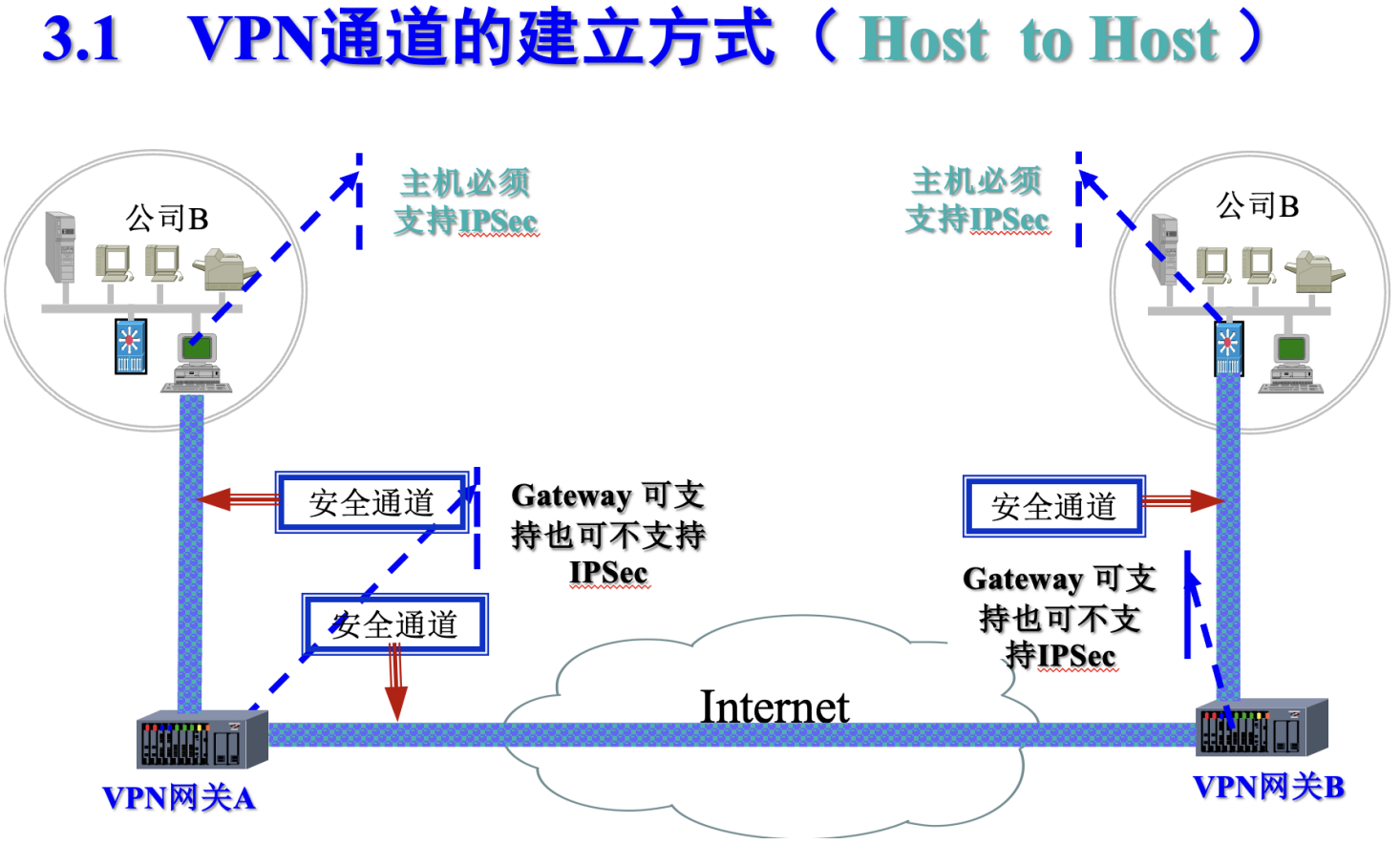
•ESP的隧道模式，先将整个IP数据包（包括IP包头）进行加密后再封装到新的IP包中，这个新的IP头中包含有安全隧道的源／宿地址。当通过ESP隧道的数据包到达目的网关（即隧道的另外一端）后，目的网关利用ESP头中的安全相关信息对加密过的原IP数据包通过安全相关处理进行还原，然后将以还原的高层数据按原IP头标明的IP地址递交，以完成通信双方信息的安全传输。

•隧道模式的ESP实施有如下的特点：保护子网中的所有用户都可以透明地享受由安全网关提供的安全保护；子网内部可以使用私有IP地址，无须公共IP地址资源；子网内部的拓扑结构被保护等。

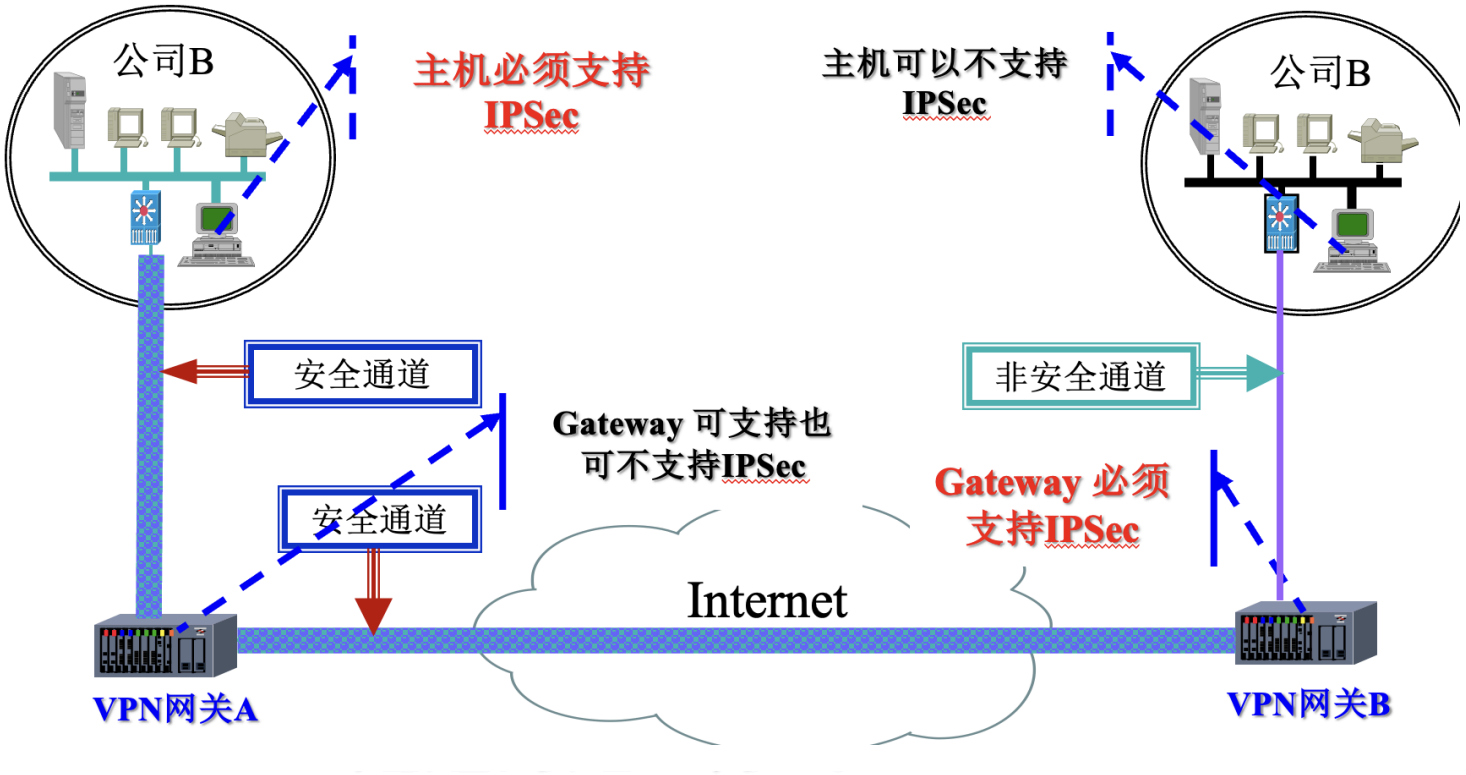
> **ESP 加密的是 ESP 头和 ESP 尾之间的数据。**

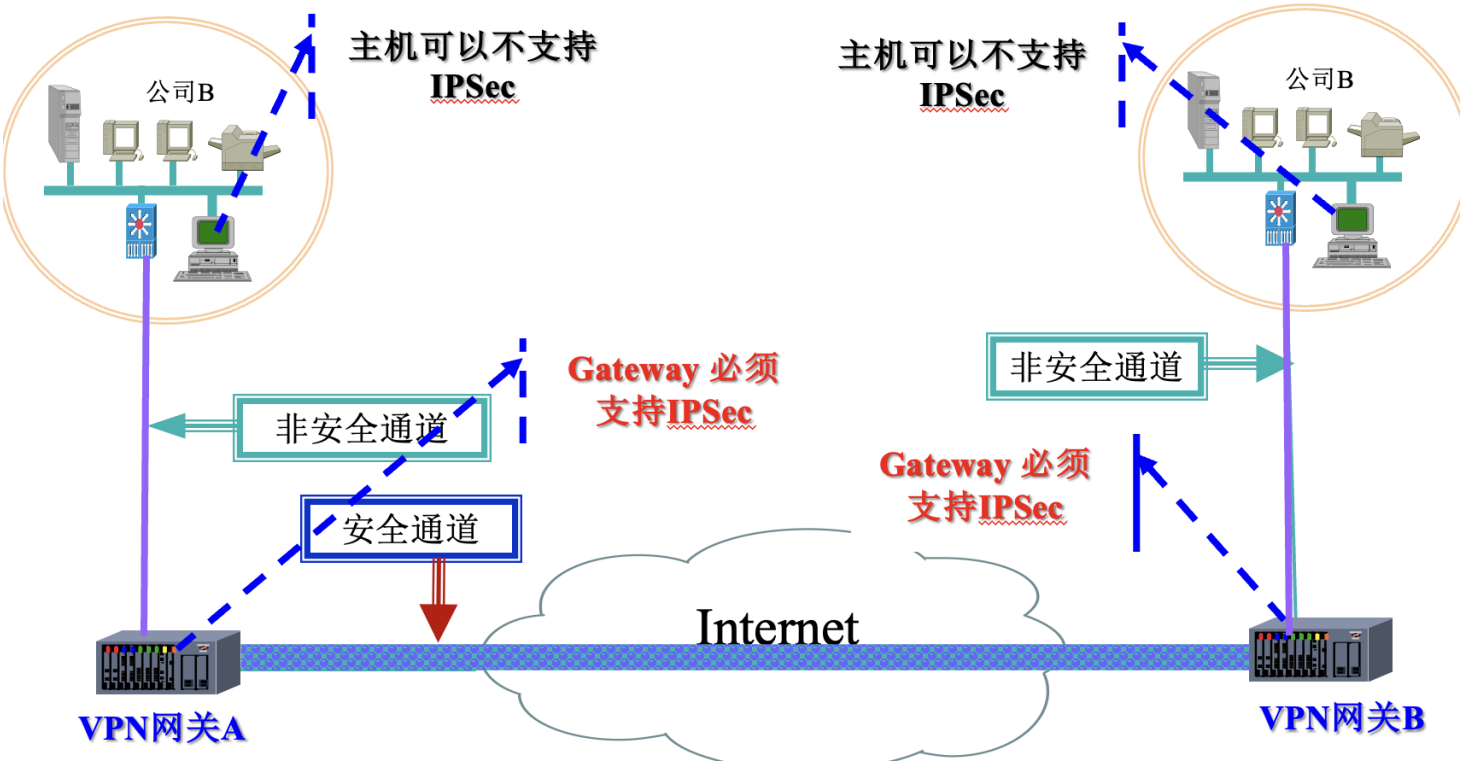
10.5 VPN 通道的四种建立方式

方式	要求
Host 对 Host	该模式要求两边主机都支持 IPSec；VPN 网关可支持也可不支持 IPSec
Host 对 VPN 网关	该模式要求 host 方主机支持 IPSec；VPN 网关 VPN 一侧需要支持 IPSec
VPN 网关对 VPN 网关	该模式不要求主机支持 IPSec；两边的 VPN 网关必须支持 IPSec
Remote User 对 VPN 网关	该模式不要求网关内主机支持 IPSec；远程用户主机必须支持 IPSec；VPN 网关必须支持 IPSec

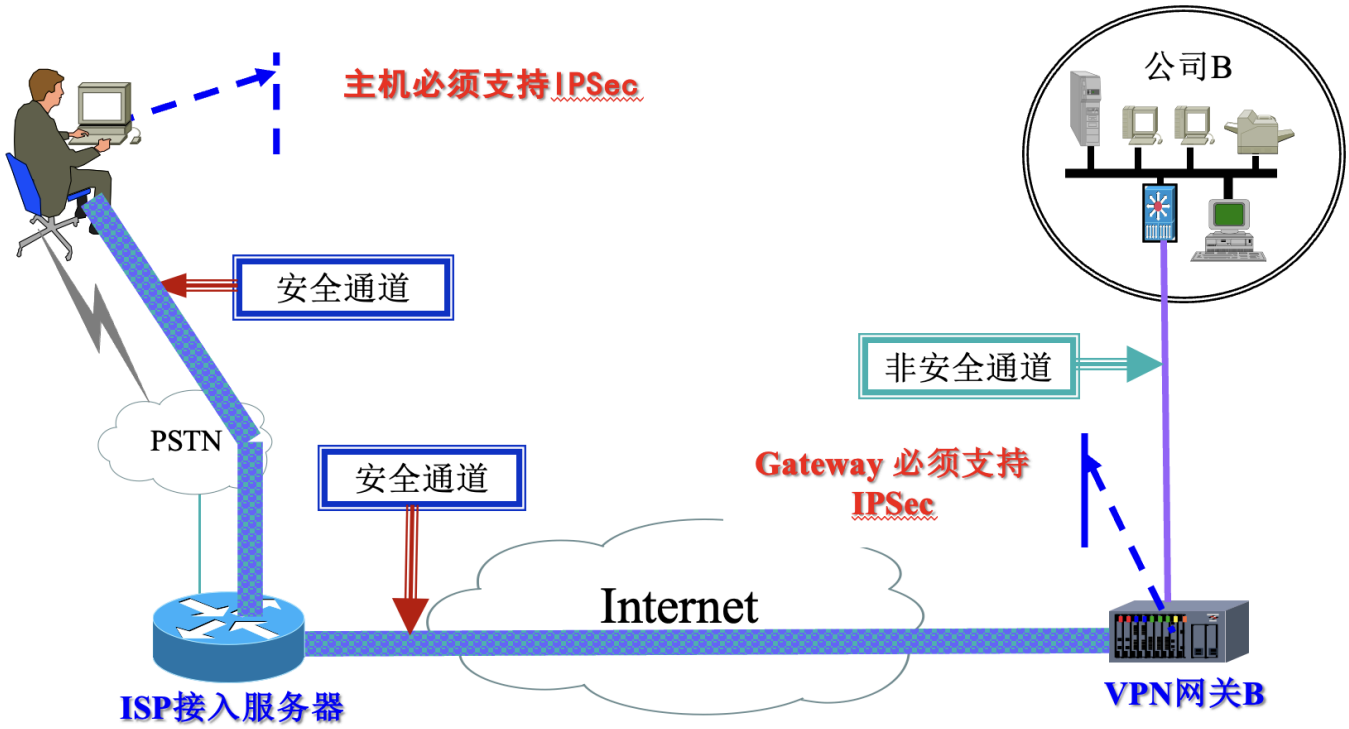


3.2 VPN通道的建立方式（Host to VPN）



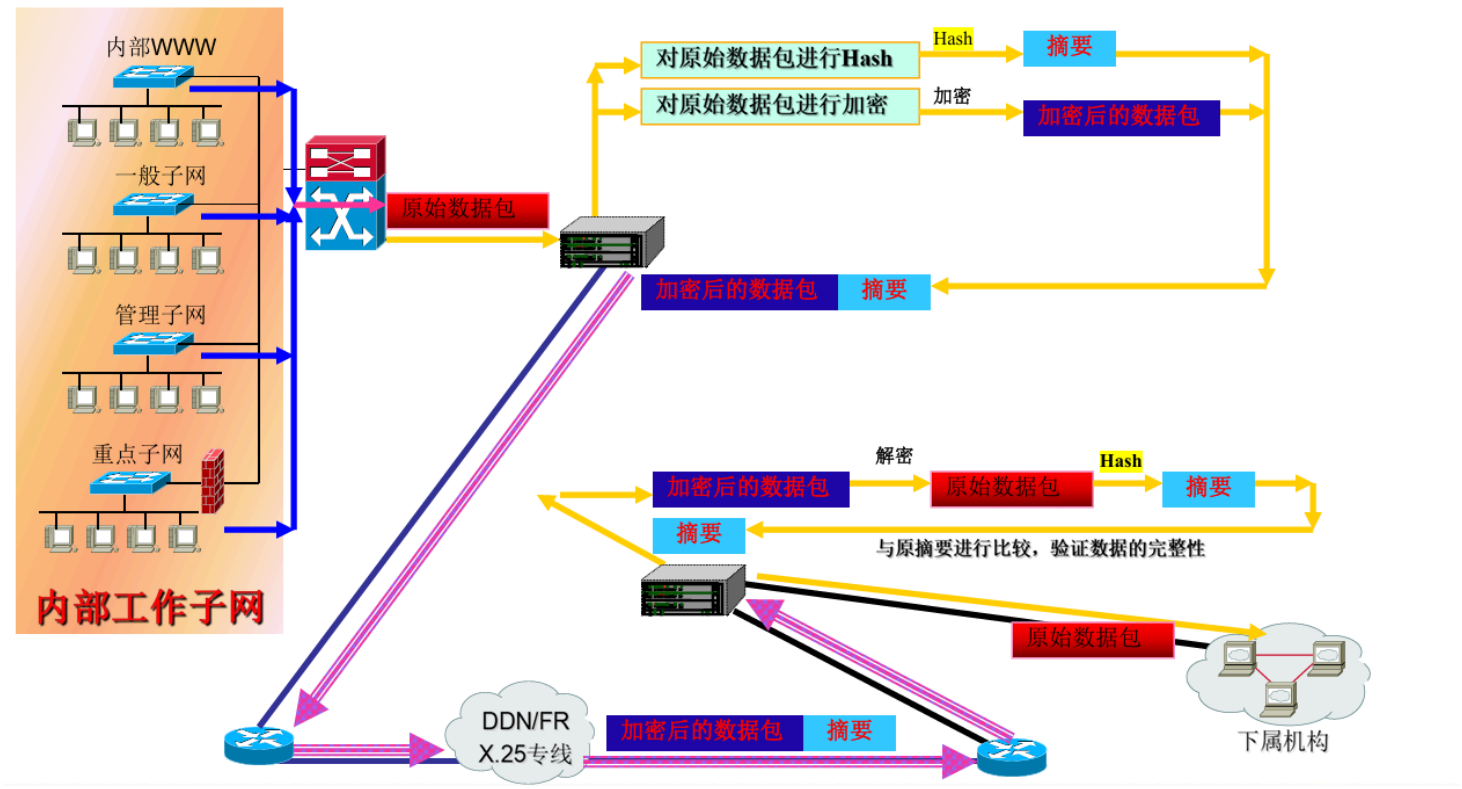


3.4 VPN通道的建立方式（Remote U to VPN）



10.6 数据完整性保护过程（重点）

发送端对原始数据包进行 Hash 运算生成"摘要"，将加密后的数据包和摘要一同传输。接收端解密数据包后，对原始数据包重新计算摘要，并与接收到的摘要进行比较，若一致则验证通过，确保数据未被篡改。



10.7 SSL 与 TLS

- **SSL**：安全套接层协议，广泛用于 Web 浏览器与服务器之间的身份认证和加密数据传输。
- **TLS**：传输层安全协议，是 SSL 的 IETF 标准化版本，类似 SSLv3 但有若干改进。

TLS

- Transport Layer Security，传输层安全
- IETF 标准RFC 2246，类似SSLv3
- 但与SSLv3有若干不同
  - 1．版本号：目前的TLS方案，主要版本是3，次要版本是1
  - 2．消息验证码：实际算法及MAC的计算范围不同
    - TLS利用RFC2104定义的HMAC算法
    - TLS的MAC计算覆盖了SSLv3计算所覆盖的所有字段，还增加了TLSCompressed.version字段

TLS（续）

- 与SSL的主要不同点
  - 3．伪随机函数：TLS使用PRF伪随机函数以扩展密码为数据块
  - 4．警告码
    - TLS支持在SSLv3中定义的所有警告码（除了no_certificate以外）
    - TLS中还定义许多附加码
  - 5．密码组：可用的密码组存在一些小的区别，TLS不包含Fortezza方案
  - 6．客户机证书类型
    - TLS在certificate_request消息中定义如下请求的证书类型：rsa_sign、dss_sign、rsa_fixed_dh和dss_fixed_dh
    - TLS不包含Fortezza方案

TLS（续）

- 与SSL 的主要不同点

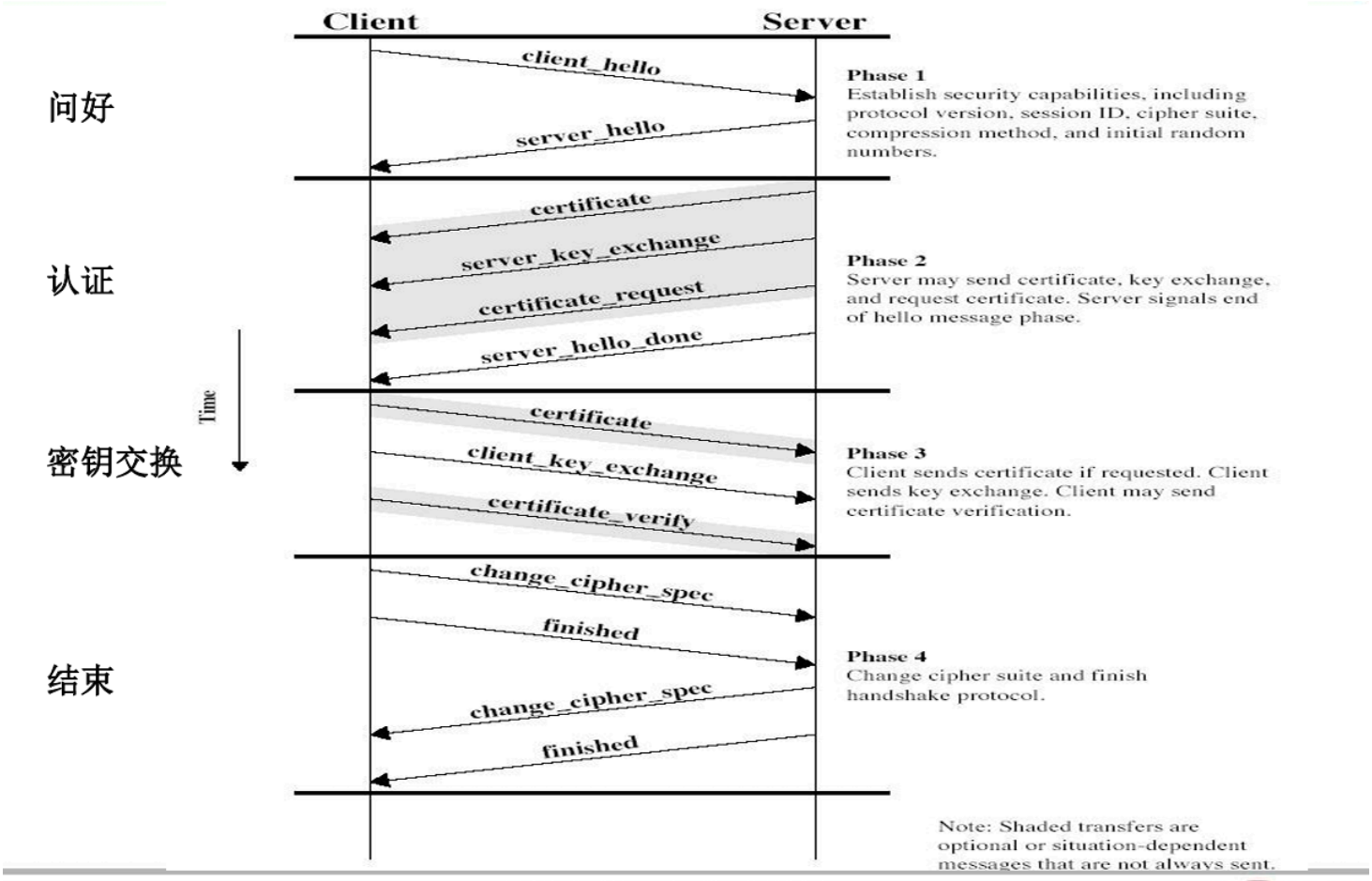
- 7. Certificate_Verify和结束消息：
  - 在TLS的certificate_verify消息中，MD5和SHA-1哈希只在handshake_messages中计算
  - TLS中的结束消息也基于共享master_secret、前面的握手消息和标识客户机或服务器的标签的哈希。但计算是不同的
- 8. 密码计算：TLS的计算方法与SSLv3的不同
- 9. 填充：
  - 在TLS中，只要使总长度是密码块长度的倍数，填充字节可以是最大到255字节的任意数量

10.8 SSL 握手

SSL 握手协议：用于在实际数据传输开始前，通讯双方进行身份认证、协商加密算法、交换加密密钥等。主要分为建立安全能力、服务器认证与密钥交换、客户端认证与密钥交换、完成四个阶段。

SSL握手协议行为过程

- 在客户机和服务器之间建立逻辑连接必须的初始交换有4个阶段
  - 第1阶段：建立安全能力
  - 第2阶段：服务器身份验证和密钥交换
  - 第3阶段：客户机验证和密钥交换
  - 第4阶段：完成



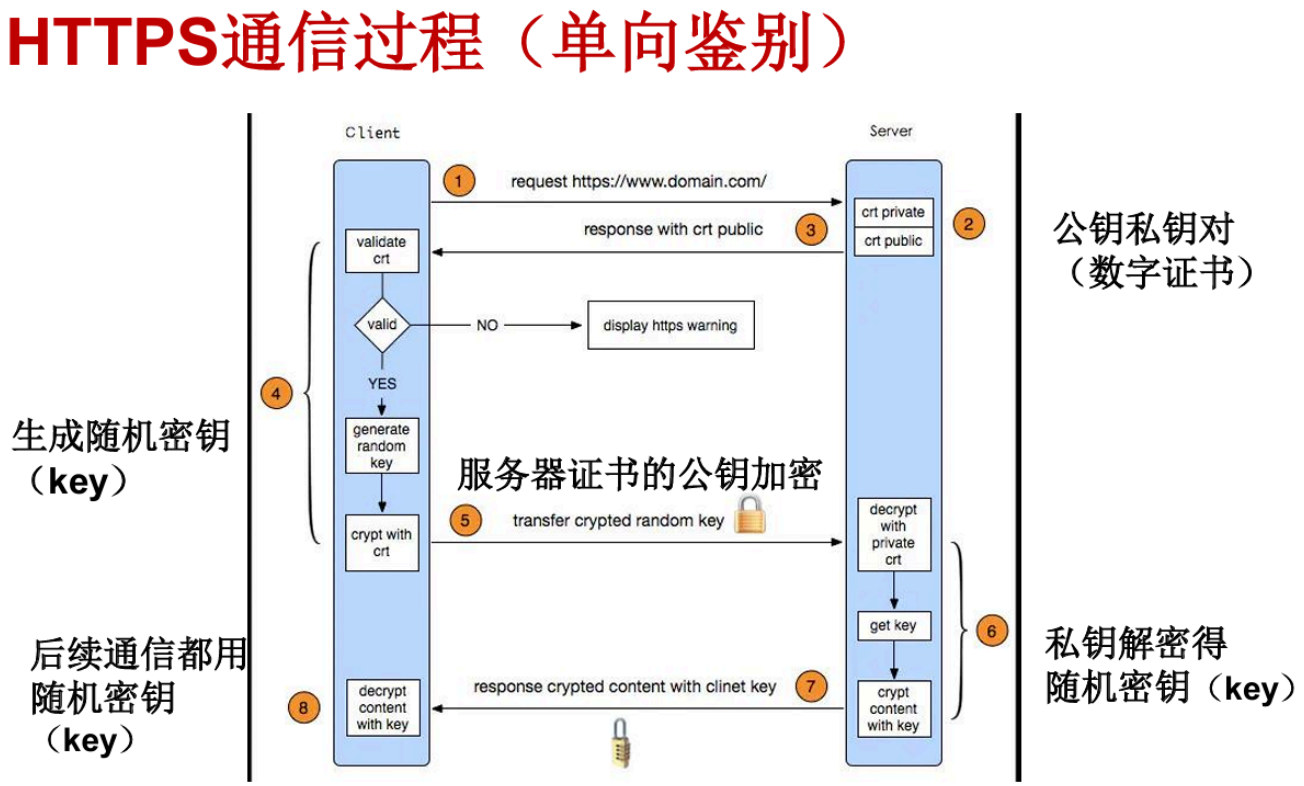
SSL握手协议行为过程（续）

- 建立安全能力，包括协议版本、会话ID、密码组、压缩方法和初始随机数字。
- 服务器可以发送证书、密钥交换和请求证书。服务器信号以hello消息段结束。
- 客户机可以发送证书。客户机发送密钥交换。客户机可以发送证书验证。
- 更改密码组并完成握手协议

10.9 HTTPS 通信过程（单向鉴别）

1. 客户端向服务器发起 HTTPS 请求。

2. 服务器生成公私钥对，通过可信机构对公钥等信息进行数字签名，形成服务器证书。
3. 服务器发送证书响应请求（公钥）。
4. 客户端验证证书，并用证书公钥加密一个随机生成的密钥（key）发送给服务器。
5. 服务器用私钥解密获得随机密钥。
6. 双方使用该随机密钥进行后续对称加密通信。



11. 系统安全

11.1 漏洞分析方法

方法	定义
静态分析	通过对源代码、字节码或可执行文件等静态数据进行分析来发现潜在漏洞和安全问题的过程。 在分析过程中，**不需要运行程序**，而是通过检查代码本身来识别潜在的漏洞
动态分析	一种采用**运行时数据**来分析软件漏洞和安全问题的方法。动态分析通常涉及执行软件程序，监视其行为， 并记录程序执行时产生的数据
模糊测试	一种**自动化的动态安全测试**方法，旨在发现软件系统中的漏洞和异常行为。在模糊测试过程中， 会向目标软件系统输入大量随机、异常或非预期的数据，监控系统的反应， 并检测系统在处理这些数据时是否会出现问题

11.2 数据安全的定义

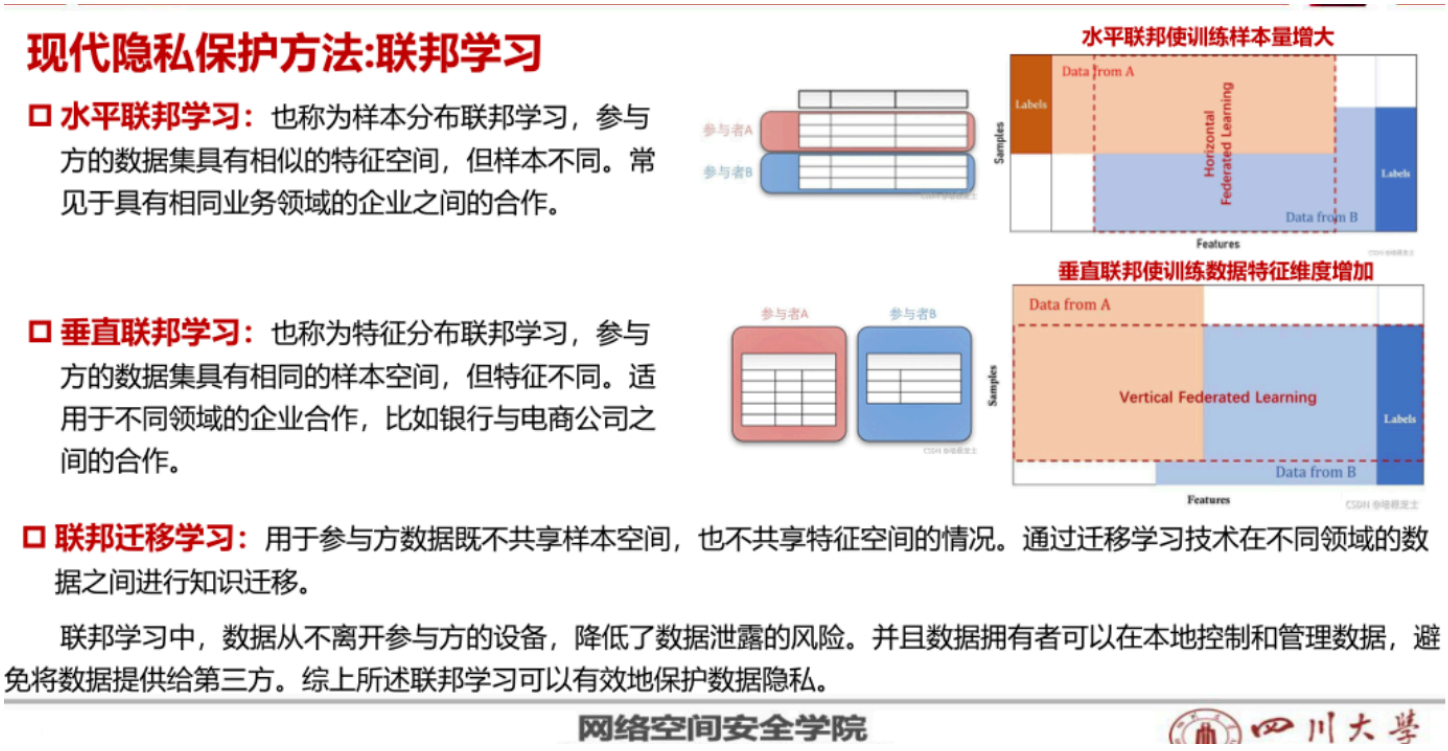
口径	定义
国家标准定义	通过管理和技术措施，确保数据有效保护和合规使用的状态

口径	定义
法律定义	通过必要措施，确保数据有效保护和合法利用，以及具备保障持续安全状态的能力

11.3 联邦学习（名词解释题）

定义：旨在不集中数据的情况下进行模型训练。联邦学习通过在分布式设备上进行本地计算，避免了数据的集中存储和传输，从而增强了数据隐私保护，同时有效利用分布式资源进行协同学习。

核心思想：联邦学习的核心是将模型分布在多个参与方（如个人设备、企业或机构）之间，每个参与方在本地训练模型，然后将训练结果（如模型参数）发送到中央服务器进行聚合，只有训练后的模型参数被共享，从而保护数据隐私。



12. 其他考点

12.1 供应链安全

12.1.1 软件供应链安全

必要性：软件供应链攻击已常态化。攻击者通过污染开源库、篡改硬件固件等方式，在软件生产与分发环节植入恶意代码，进而渗透目标系统，造成广泛影响。

影响方面

- **开源产品后门**：攻击者可向 NPM、PyPI 等公共开源仓库投毒，使依赖这些开源组件的产品被植入后门。
- **企业名誉与业务**：供应链攻击可导致企业系统被控、数据泄露、服务中断，造成重大经济损失并严重损害企业声誉。

12.1.2 数据供应链安全

是什么：数据供应链涉及数据从产生、传输、存储、处理到销毁的**全生命周期**。其安全核心是确保数据在整个链条中的机密性、完整性和可用性。

应用场景与风险：在物联网、云计算、大数据等场景中，数据在多个实体间流动。风险包括：数据在传输或存储时被窃取（**机密性破坏**）、被非法篡改（**完整性破坏**）、以及因系统故障或攻击导致无法访问（**可用性破坏**）。

12.1.3 物理供应链安全

核心要点：物理安全是信息安全的基础，常被忽视。它确保信息系统所在的物理环境（如数据中心）和硬件设备本身的安全。

风险案例：攻击者可利用物理安全漏洞（如门禁设计缺陷）接触设备，直接植入恶意硬件或窃取数据。管理疏忽（如"忘记关门"）是物理安全的最大威胁之一。

12.1.4 关联与总结

软件、数据、物理供应链安全是网络空间安全的重要组成部分。安全是**动态、相对**的，需要技术、管理和人员意识相结合，并在安全与发展、开放与防护之间取得平衡。

12.2 特殊通信场景安全

12.2.1 卫星通信的安全威胁与防护

卫星通信把节点搬到天上，链路变成"地面站—卫星—地面站"的空中微波中继。**安全上最大的变化是：攻击面从"网络内部"扩展到了"物理可达的无线信道"**——传统有线链路上"偷不到线"的天然屏障消失了。

> 链路的**性能特性**（时延取舍、窗口下限、对 TCP 的影响、vs 地面蜂窝）见 物理层 §卫星通信 和 TCP 拥塞控制 §大 RTT 链路，本节只补**安全**维度。

三类典型威胁

威胁	作用的安全属性	说明
窃听与截获	**机密性**	无线信道开放，信号可被任意接收方捕获；若链路层不加密，内容即为明文
干扰与压制	**可用性**	窄带压制、宽带阻塞、功率压制直接淹没信号；导航场景还存在 **GPS 欺骗**——伪造导航信号使终端定位错误
欺骗与劫持	**完整性 + 身份真实性**	伪造合法卫星或终端身份接管链路；地面站设备物理暴露，易被接触后植入

对应的安全机制

机制	解决什么	说明
链路层与应用层加密	窃听	对信道数据直接加密，弥补无线信道的开放性
IPsec 隧道模式	窃听 + 拓扑暴露	跨广域/星地链路建立端到端安全通道。隧道模式**封装整个原始 IP 分组**，因此能隐藏内部网络地址、**保护子网内部拓扑**（见 §10.4.2）——这在跨越不可控的空域链路时尤其关键
身份认证与完整性保护	欺骗 + 篡改	双向鉴别确认通信对端身份；用 AH/ESP 的完整性校验与**抗重放**字段防止数据被篡改和重放
抗干扰技术	干扰压制	扩频、跳频、纠错编码、自适应编码调制，提高抗窄带干扰与衰落能力

机制	解决什么	说明
物理防护与冗余	物理攻击与单点失效	地面站机房门禁、电磁屏蔽；多星/多路径备份，避免单点被物理接管

说白了，卫星通信的威胁全部来自**无线信道是敞开的**，一共三类：信号被人收走（窃听）、信号被人压掉（干扰）、有人冒充通信的一方（欺骗）。

前两类分别靠加密和抗干扰技术挡住，第三类靠身份认证加完整性校验挡住。

题目问"**两种**安全威胁"时，两个答案要来自**不同维度**——比如机密性配可用性，或者机密性配真实性。不要把"窃听"和"截获"这种同源说法拆成两种答，那只算一种。

网络安全科完结。回顾：网络安全（上）——概念、风险模型、鉴别与访问控制 | 总索引